Phishing Email Investigation.

Time Used

Approximately 2–3 hours

1. Introduction

The purpose of this project was to investigate a suspicious email claiming that the user's iCloud storage was full.

The email asked the user to provide credit-card information for Apple ID validation.

I used Kali Linux and the provided `phishing.eml` file to check the email headers, authentication results, email content, URLs, domains, and indicators of phishing.

The links in the email were not opened during the investigation.

---

2. Email Overview

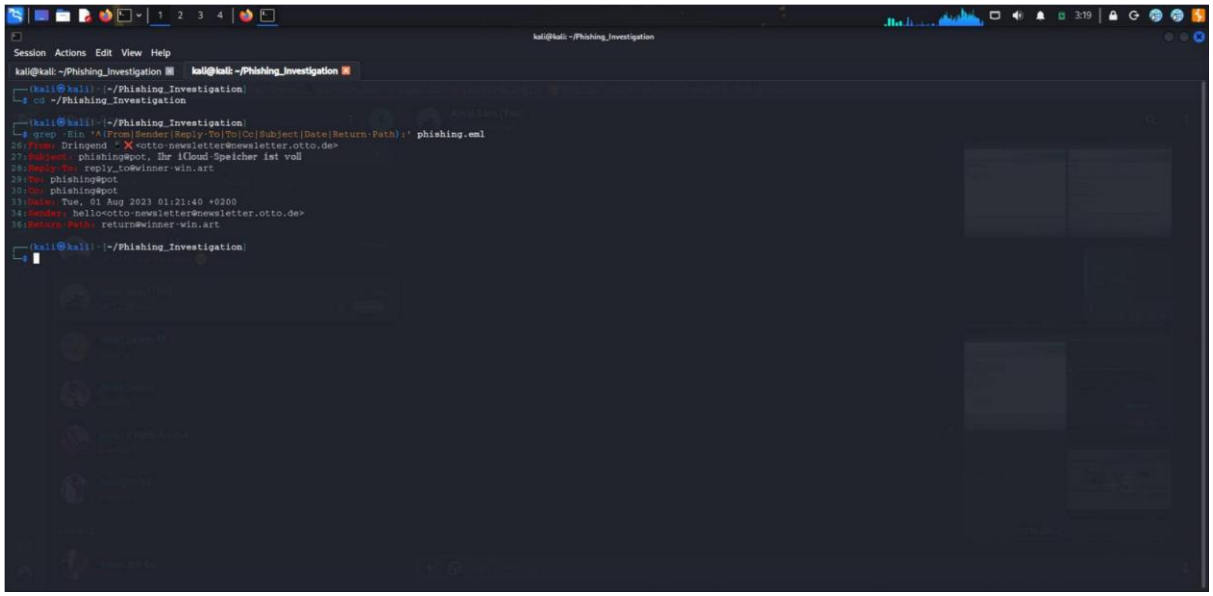
The main email details were checked from the email headers.

The following information was identified:

- From: `otto-newsletter@newsletter.otto.de`
- Subject: iCloud storage is full
- Reply-To: `reply_to@winner-win.art` Return-Path: `return@winner-win.art`
- To: `phishing@pot`
- Date: `Tue, 01 Aug 2023 01:21:40 +0200`

The From address and the Reply-To/Return-Path addresses were different.

Email Header Evidence



Email header information extracted from phishing.eml.

---

3. Header Analysis

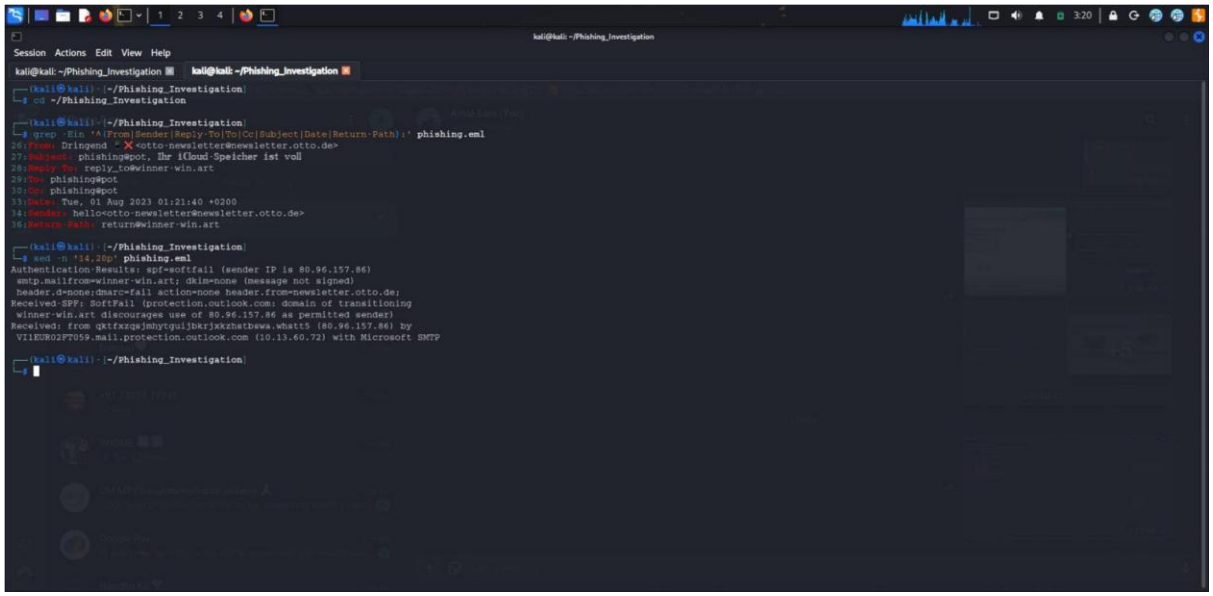
The email authentication information was checked from the headers.

The following results were found:

- Sender IP: `80.96.157.86`
- SPF: **SoftFail**
- DKIM: **None**
- DMARC: **Fail**
- SPF mail-from domain: `winner-win.art`
- From domain: `newsletter.otto.de`

The authentication results showed problems with SPF and DMARC, and the message did not have a DKIM signature.

Authentication Evidence



SPF, DKIM, DMARC and sender IP information.

---

4. Phishing Indicators

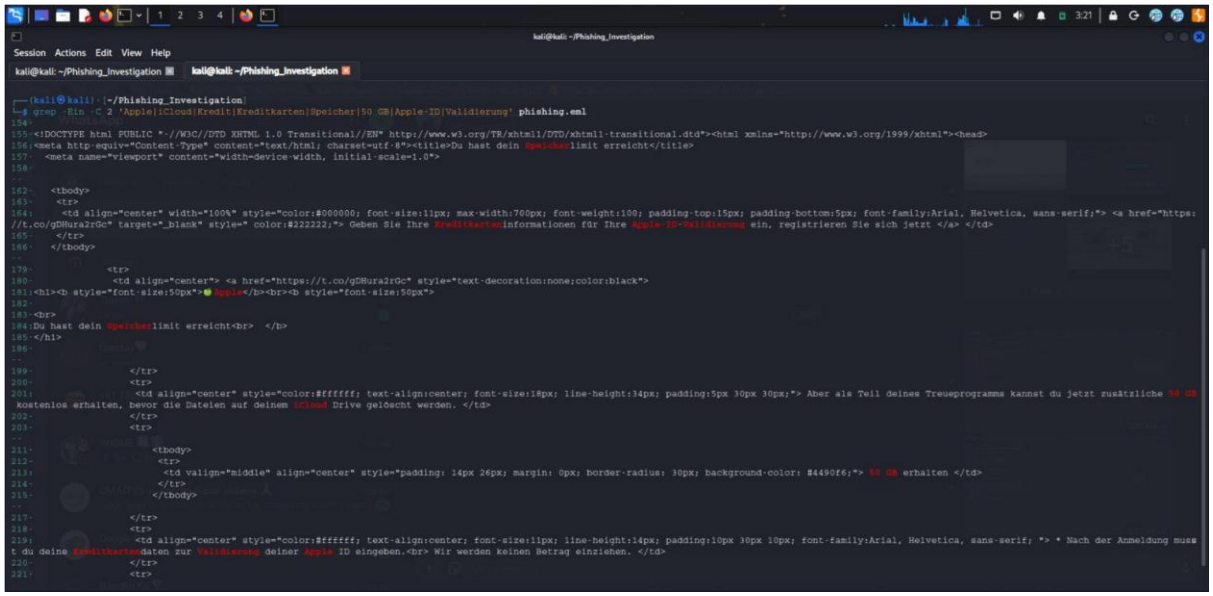
The email content was checked for suspicious information.

The following indicators were found:

- Apple branding was used.
- The email claimed that the iCloud storage limit had been reached.
- It warned that files could be deleted.
- It offered an additional 50 GB of storage.
- It asked for credit-card information.
- It asked for credit-card details to validate the Apple ID. A link was provided to continue the process.

These points indicate that the email was designed to look like an Apple/iCloud message and collect sensitive information.

Phishing Content Evidence



Apple/iCloud branding, storage warning and credit-card request.

---

5. URL and Domain Analysis

The URLs inside the email were extracted without opening them.

The main URLs found were:

- `https://t.co/gDHura2rGc`
- `http://bsq2.firiri.shop/...`

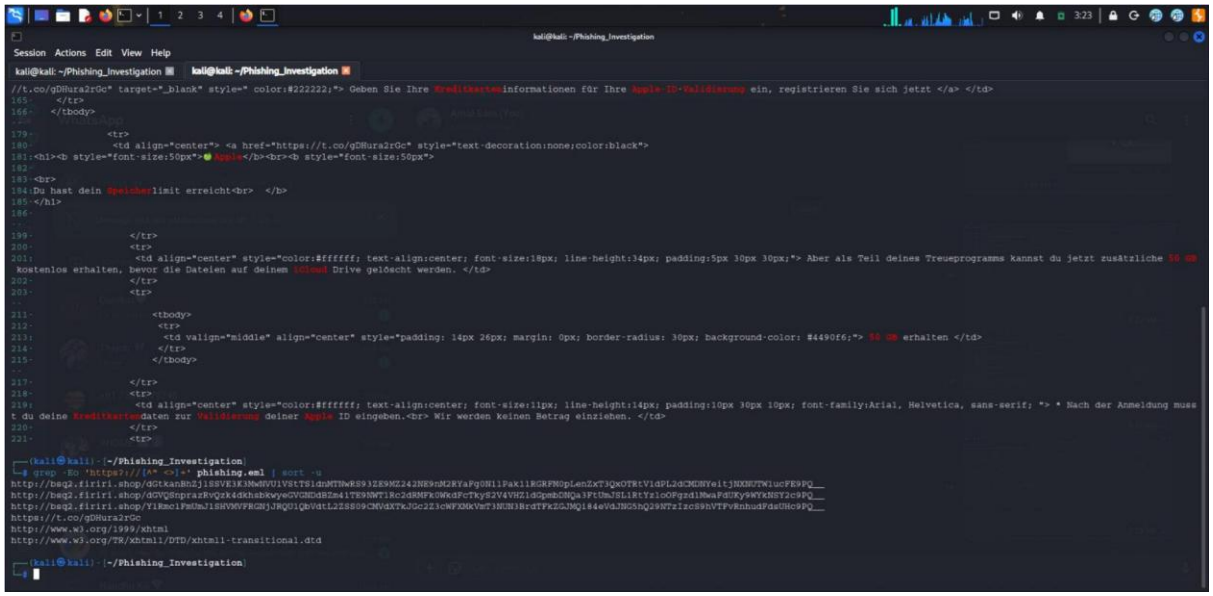
The following domains were identified:

- `t.co`
- `bsq2.firiri.shop`
- `www.w3.org`

The `t.co` URL is a shortened URL. The `bsq2.firiri.shop` domain was recorded as a suspicious domain found in the email.

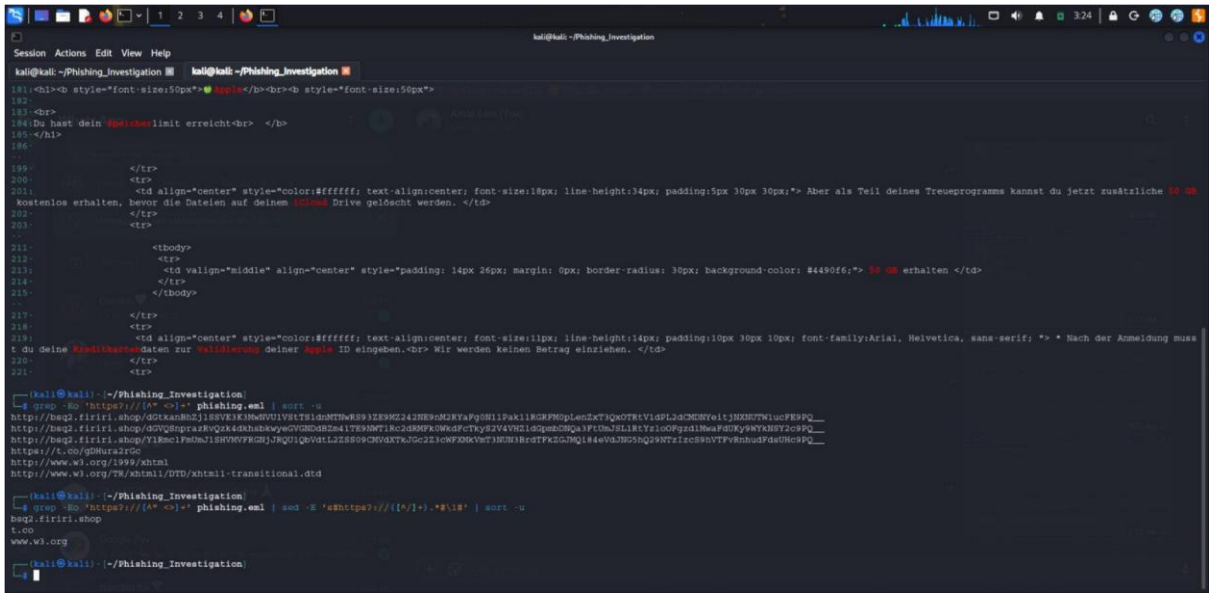
The `www.w3.org` URLs were related to the HTML document format and were not treated as phishing indicators.

URL Evidence



URLs extracted from the phishing email.

Domain Evidence



Domains extracted from the email URLs.

---

6. Risk Assessment

Based on the evidence collected, the email was classified as:

Classification: Phishing

Risk Level: High
The classification was based on the authentication failures, different email domains, Apple/iCloud branding, storage warning, credit-card request, and suspicious URLs.

The request for credit-card information makes the email a high-risk message.

---

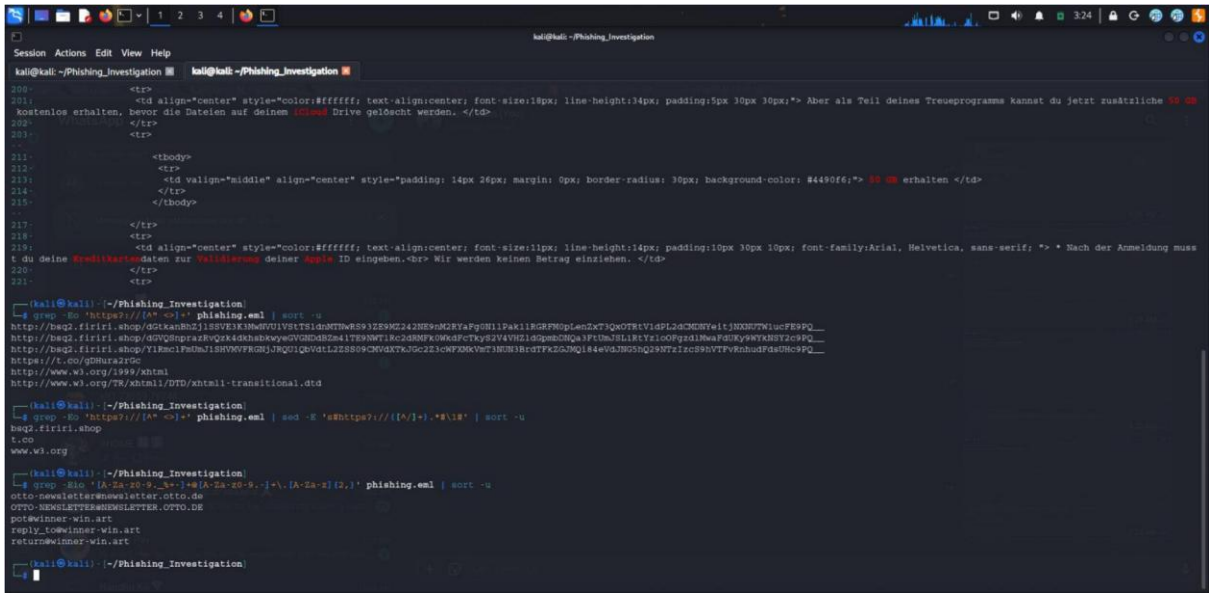
7. IOC Collection

The following indicators were collected during the investigation:

- Sender IP: `80.96.157.86`
- From: `otto-newsletter@newsletter.otto.de`
- Reply-To: `reply_to@winner-win.art`
- Return-Path: `return@winner-win.art` Additional email: `pot@winner-win.art`
- Suspicious domain: `bsq2.firiri.shop`
- Shortened URL: `https://t.co/gDHura2rGc` The SHA-256 hash of the evidence file was:

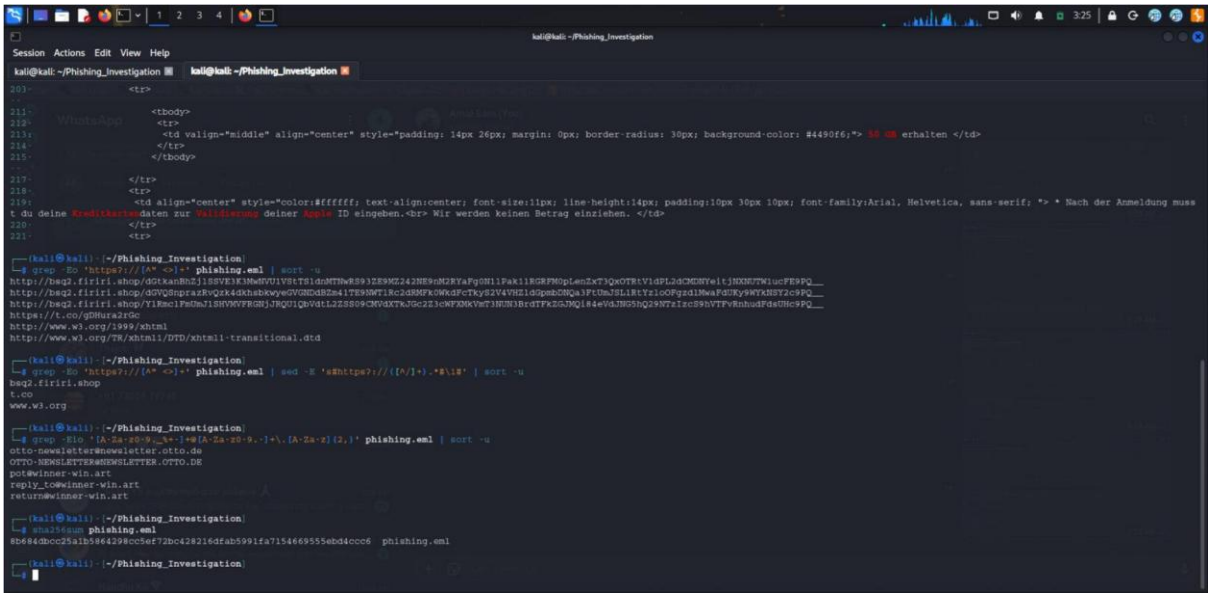
`8b684dbcc25a1b5864298cc5ef72bc428216dfab5991fa7154669555ebd4ccc6`

IOC Evidence



Email addresses and IOC information extracted from the email.

File Hash Evidence



SHA-256 hash of phishing.eml.

---

8. Recommendations

For the User

- Do not click the links in the email.
- Do not provide credit-card information.
- Do not enter Apple ID details through the email.
- Report the email as phishing.
- Delete the email after preserving the evidence if required.

For the Security Team

- Block or monitor the identified suspicious indicators.
- Search for similar emails in other mailboxes.
- Check whether any users clicked the links or submitted information. □ Keep the original `.eml` file for further investigation.

---

9. Main Findings

The main findings from the investigation were:

- Sender IP identified as `80.96.157.86`. □ SPF result was SoftFail.

- DKIM was not present.
- DMARC result was Fail.
- From domain was different from the Reply-To and Return-Path domains.
- Apple/iCloud branding was used.
- The email claimed that the iCloud storage was full. □ The email requested credit-card information.
- A shortened `t.co` URL was present.
- `bsq2.firiri.shop` was identified as a suspicious domain in the email. □ The email was classified as phishing.
- The risk level was assessed as High.
- No URLs were opened during the investigation.

---

10. Conclusion

The investigated email was identified as a phishing email based on the evidence collected from `phishing.eml`.

The email used Apple/iCloud-related content and a storage warning to create urgency. It then requested credit-card information for Apple ID validation.

The email also showed SPF SoftFail, no DKIM signature, and DMARC Fail. The From address was different from the Reply-To and Return-Path addresses.

The investigation was limited to safe analysis of the provided email file. No links were opened and no information was submitted.

The identified email and URL indicators should be reported and monitored to reduce the risk of similar phishing attempts.